

Supply Chain Attack response

Supply Chain / DevSecOps · **Critical** severity · SOC IR Playbook

Incident type	Supply Chain Compromise
Severity	Critical
Priority	Critical
Detection sources	Threat intelligence, SIEM, EDR, vulnerability reports, system anomalies

Scenario

An organisation is compromised through a trusted third-party service, software update, library, plugin or IT service provider. The attacker uses the trusted relationship to move laterally, deploy malware or exfiltrate data.

MITRE ATT&CK

T1105, T1195.001, T1195.002

Preparation

Maintain third-party inventory List all vendors, software providers and integrations Conduct risk assessments Evaluate criticality and access level of each vendor or dependency Apply access restrictions Use segmentation and least privilege for third-party services Monitor software behaviour Enable logging and behavioural analysis for all installed components Validate software updates Use secure channels and signed binaries for critical applications

Detection & Analysis

Identify abnormal behaviour Outbound connections, registry changes, dropped files, execution from unexpected paths Verify against threat intelligence Check IoCs related to known supply chain breaches (e.g., SolarWinds, MOVEit, Kaseya) Examine affected components Determine if recent updates or third-party access triggered the behaviour Review vendor communications Check for public disclosures or breach notifications

Containment

Disconnect affected systems Prevent lateral movement and external communication Suspend integrations or services Disable connections to affected vendor software, APIs or modules Block malicious binaries or signatures Use EDR/XDR to prevent execution of known malicious components Quarantine suspicious hosts Isolate endpoints communicating with attacker infrastructure

Eradication

Remove malicious files or updates Uninstall or roll back infected or trojanised software Validate software integrity Use hash comparison or vendor-signed binaries Remove backdoors or persistence Clean registry keys, scheduled tasks, rogue accounts or remote access tools Update detection rules Add new IoCs to SIEM and EDR platforms for early detection of reoccurrence

Recovery

Reinstall from clean source Use validated installation media or updated software versions Restore from backup Only if backup is verified to be unaffected Re-establish vendor connection After patching or validation by third-party provider Resume normal operations After containment and eradication are fully verified

Lessons Learned & Reporting

Conduct a post-incident review Determine timeline, attack path, vendor involvement Update third-party risk program Introduce more stringent onboarding, auditing and segmentation rules Inform stakeholders Notify management, legal and affected business units Collaborate with the vendor Share findings and request full disclosure on their mitigation status Report if required Regulatory and contractual obligations (e.g., PDPA, GDPR, customer SLAs)

Tools typically involved

SIEM (e.g., Splunk, Sentinel, QRadar); EDR/XDR (e.g., CrowdStrike, Cortex XDR); Threat intelligence platforms (e.g., MISP, Recorded Future); Software integrity validation (e.g., sigcheck, file hashing tools); Configuration management tools (e.g., SCCM, Ansible, JAMF)

Success metrics (SLA targets)

Vendor Notification Response Time Within 24 hours of known vendor disclosure
Compromise Detection Time <6 hours after initial signs
Isolation & Containment Time <2 hours after confirmation
Remediation Completion Time Within 48-72 hours for critical systems
Third-Party Reassessment Completion Within 7 days of incident closure